Risk analysis and management for ICT systems

Introduction to risk management methodology, juridical aspects and case studies

Stefano Zatti and Raffaele Gargiulo

DIPARTIMENTO
DI INFORMATICA



SAPIENZA
UNIVERSITÀ DI ROMA

Risk analysis and management (ZATTI)

1. Introduction. The ISO 27000 family of standards
2. The ISO 27005 standard for management of information security risks
3. Similar standards: NIST 800-30
4. Methodologies: Octave, EBIOS, ...
5. The threat profile from ENISA
6. The implementation of the ISMS - how to start a project - phases of risk assessment
7. Asset inventory and scope definition. Threats and vulnerabilities
8. Risk evaluation, risk treatment, countermeasures, communication
9. Case study: the corporate ICT system
10. Case study: Cyber security of Space Missions

INTERNATIONAL STANDARD

ISO/IEC 27005

Fourth edition
2022-10

Information security, cybersecurity and privacy protection — Guidance on managing information security risks

Sécurité de l'information, cybersécurité et protection de la vie privée — Préconisations pour la gestion des risques liés à la sécurité de l'information

What is Risk Assessment?

- **Risk**: effect of uncertainty on objectives (ISO 31000)
- **ISO 27000 - 2.71**

risk assessment

overall process (2.61) of risk identification (2.75), risk analysis (2.70) and risk evaluation (2.74)

- **ISO 27005**

Risk Assessment = Identification, Analysis and Evaluation

- **NIST SP 800-30**

Risk Assessment is the analysis of threats in conjunction

with vulnerabilities and existing controls.

What is Risk Assessment?

- Business rationale

Function	Explanation
Return on Investment	Structured RA Methodology follows a systematic and pre-defined approach, minimizes the scope of human error, and emphasizes process driven, rather than human driven activities.
Budget Allocation	Assists in controls cost planning and justification
Controls	Cost and effort optimization by optimizing controls selection and implementation
Efficient utilization of resources	Resource optimization by appropriate delegation of actions related to controls implementation.

What is IS - Risk Assessment?

- Risk assessment is the cornerstone of any *information security program*, and it is the **fastest** way to gain a complete understanding of an **organization's** security profile --- its strengths and weaknesses its vulnerabilities and **exposures**.

"IF YOU CAN'T MEASURE IT…
YOU CAN'T MANAGE IT!"

The link with ISO 27001 on RISK management

- 6.1.2. Information Security Risk assessment
  - The organization shall define and apply an Information security risk assessment process
- 6.1.3. Information Security Risk treatment
  - The organization shall define and apply an information security risk treatment process
- 9.2 Internal audit

Reality Check

- IS-RA – a need more than a want
- Each organization has its own IS-RA
- IS-RA has a learning curve
- Cumbersome - potentially…

  1000 assets, 20 worksheets
- Effort is required (no free meal)
- It gets complicated
- Need to accurately document and report
- Fundamental to prevent and avoid disasters
- Useful to convince management to invest *as much as needed* in order to avoid negative impacts

Risk Assessment reference points

- ISO 31000
- ISO 27005
- OCTAVE
- NIST SP 800-30
- EBIOS
- Mehari

Definitions from ISO 27000

- **2.68 Risk**: effect of uncertainty on objectives
- **2.83 Threat:** potential cause of an unwanted incident, which may result in harm to a system or organization.

  Needs to succeed: *intention, capability, opportunity*
- **2.89 Vulnerability:** weakness of an asset or *control* (2.16) that can be exploited by one or more *threats* (2.83)
- **2.16 Control:** measure that is modifying risk (2.68)

Definitions from ISO 27005:2022

3.1.3 Risk: effect of uncertainty on objectives

3.1.5 risk owner: person or entity with the accountability and authority to manage a *risk* (3.1.3)

3.1.6 risk source: element which alone or in combination has the potential to give rise to *risk* (3.1.3)

3.1.7 risk criteria: terms of reference against which the significance of a *risk* (3.1.3) is evaluated

3.1.8 risk appetite: amount and type of *risk* (3.1.3) that an organization is willing to pursue or retain

3.1.9 threat: potential cause of an *information security incident*, that can result in damage to a system or harm to an organization

3.1.10 vulnerability: weakness of an asset or *control* (3.1.16) that can be exploited so that an *event* with a negative *consequence* (3.1.14) occurs

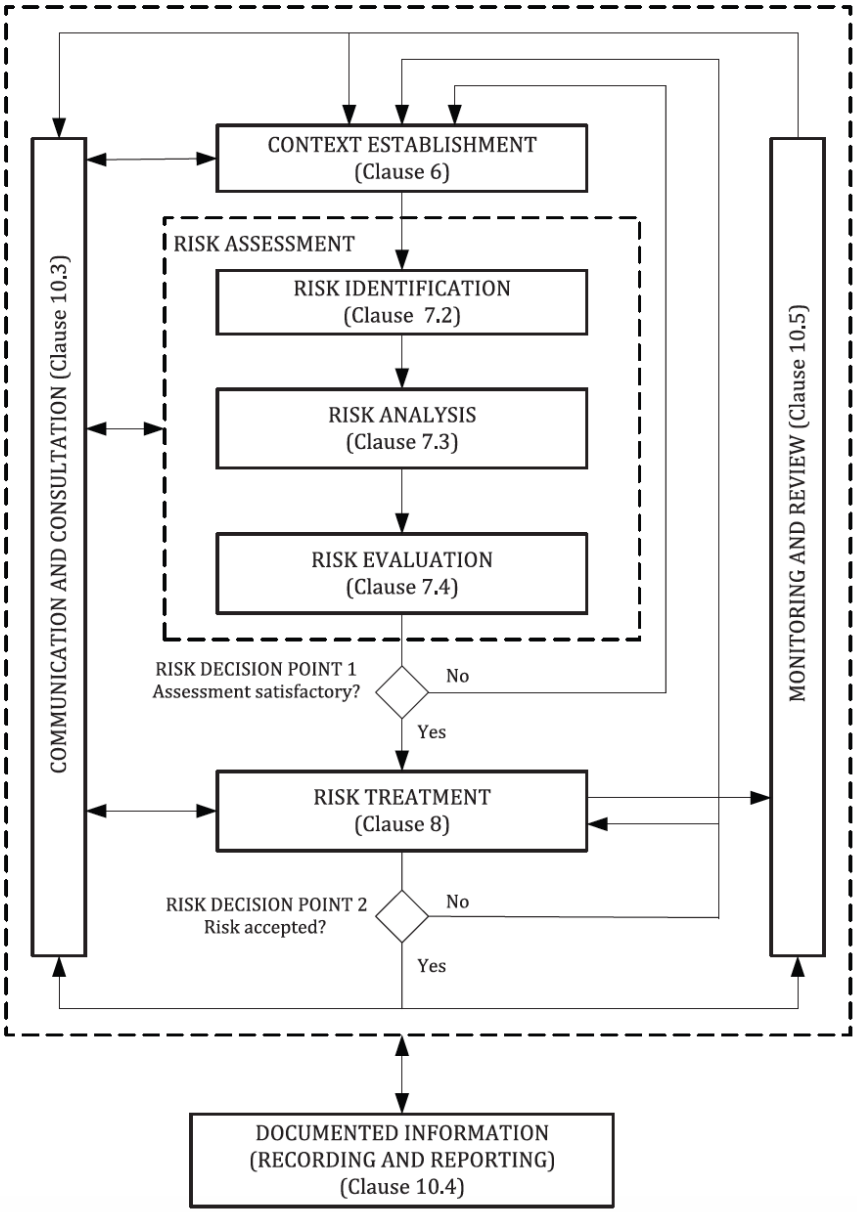
3.1.16 control: measure that maintains or modifies *risk* (3.1.3)

ISO 27005 Introduction

- ISO 27005:2022 provides guidance on managing information security risks.
- Lays emphasis on the **ISMS** concept of ISO 27001:2022.
- Drafted and published by the International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC)
- Provides a RA guideline and **does not recommend** any RA methodologies.
- Applicable to organizations of all types.

Information security risk management process

- Advocates an iterative approach to risk assessment
- Aims at balancing time and effort with controls efficiency in mitigating high risks
- Proposes the PDCA cycle of continuous improvement at the strategic and operational level



Benefits of risk management

Information security risk management should contribute to the following:

- risks being identified;
- risks being assessed in terms of their consequences to the business and the likelihood of their occurrence;
- the likelihood and consequences of these risks being communicated and understood;
- priority order for risk treatment being established;
- priority for actions to reduce risks occurring;
- stakeholders being involved when risk management decisions are made and kept informed of the risk management status;
- effectiveness of risk treatment monitoring;
- risks and the risk management process being monitored and reviewed regularly;
- information being captured to improve the risk management approach;
- managers and staff being educated about the risks and the actions taken to mitigate them.

Risk management approach

Depending on the scope and objectives of the risk management, different approaches can be applied. The approach can also be different for each iteration.

An appropriate risk management approach should be selected or developed that addresses basic criteria such as: ***risk evaluation criteria, impact criteria, risk acceptance criteria.***

Additionally, the organization should assess whether necessary resources are available to:

- perform risk assessment and establish a risk treatment plan;
- define and implement policies and procedures, including implementation of the controls selected;
- monitor controls; and
- monitor the information security risk management process.

Risk acceptance criteria (1/2)

Risk acceptance criteria (6.4.2) should be developed and specified. Risk acceptance criteria often and the interests of stakeholders.

In risk evaluation, risk acceptance criteria should be used to determine whether a risk is acceptable or not.

In risk treatment, risk acceptance criteria can be used to determine whether the proposed risk treatment is sufficient to reach an acceptable level of risk, or if further risk treatment is needed

An organization should define its own levels of risk acceptance depending on the organization's policies, goals, objectives (risk appetite).

The following should be considered during development:

- risk acceptance criteria can include multiple thresholds, with a desired target level of risk, with the provision for senior managers to accept risks above this level under defined circumstances;
- risk acceptance criteria can be expressed as the ratio of estimated profit (or other business benefit) to the estimated risk;
- different risk acceptance criteria can apply to different classes of risk;
- risk acceptance criteria can include requirements for future additional treatment, e.g. a risk can be accepted if there is approval and commitment to take action to reduce it to an acceptable level within a defined time period

Risk acceptance criteria (2/2)

Risk acceptance criteria can differ according to how long the risk is expected to exist, e.g. the risk can be associated with a temporary or short-term activity.

Risk acceptance criteria should be set up considering the **Risk appetite** of the organization and of its management, based upon:

- business criteria;
- operations;
- technology;
- finance;
- Social and humanitarian factors

Organization for information security risk management

The organization and responsibilities for the information security risk management process should be set up and maintained, whose main roles and responsibilities are:

- development of the information security risk management process suitable for the organization;
- identification and analysis of the stakeholders;
- definition of roles and responsibilities of all parties both internal and external to the organization;
- establishment of the required relationships between the organization and stakeholders, as well as interfaces to the organization's high-level risk management functions (e.g. operational risk management), as well as interfaces to other relevant projects or activities;
- definition of decision escalation paths;
- specification of records to be kept.

This organization should be approved by the manager(s) of the organization.

Risk analysis methodologies: qualitative

Qualitative risk analysis uses a scale of qualifying attributes to describe the magnitude of potential consequences (e.g. low, medium and high) and the likelihood that those consequences will occur. An advantage of qualitative analysis is its ease of understanding by all relevant personnel while a disadvantage is the dependence on subjective choice of the scale.

These scales can be adapted or adjusted to suit the circumstances and different descriptions can be used for different risks. Qualitative risk analysis can be used:

- as an initial screening activity to identify risks that require more detailed analysis;
- where this kind of analysis is appropriate for decisions;
- where the numerical data or resources are inadequate for a quantitative risk analysis.

Qualitative analysis should use factual information and data where available.

Risk analysis methodologies: quantitative

Quantitative risk analysis uses a scale with **numerical** values for both consequences and likelihood, using data from a variety of sources. The quality of the analysis depends on the accuracy and completeness of the numerical values and the validity of the models used.

Quantitative risk analysis, in most cases, uses historical incident data, providing the advantage that it can be related directly to the information security objectives and concerns of the organization.

A disadvantage is the lack of such data on new risks or information security weaknesses, where factual, auditable data is not available, thus creating an illusion of worth and accuracy of the risk assessment.

The uncertainty and variability of both consequences and likelihood should be considered in the analysis and communicated effectively.

ISO 27005 Risk Assessment

- Information Security Risk Assessment =

Risk Identification + Risk Analysis + Risk Evaluation

- Risk Identification
  - Risk characterized in terms of organizational conditions
    - » Identification of Assets: Assets within the defined scope
    - » Identification of Threats: Based on Incident Reviewing, Asset Owners, Asset Users, External threats, etc.

ISO 27005 Risk Assessment

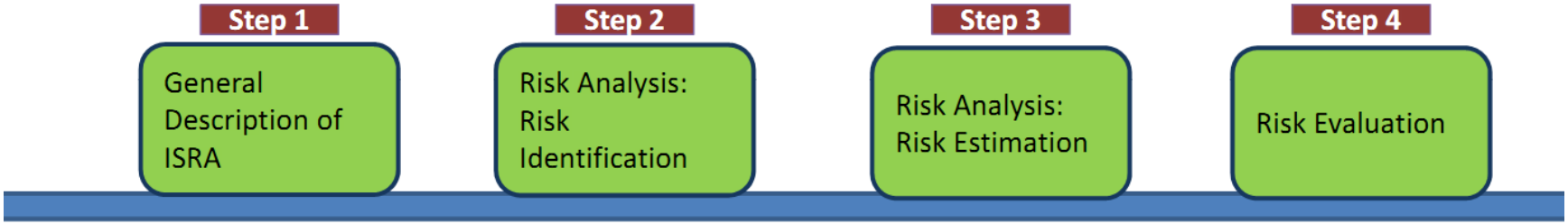
- Information Security Risk Assessment (ISRA)=

Risk Identification + Risk Analysis + Risk Evaluation

- Risk Analysis:
  - Risk Analysis = Risk Estimation
    - Risk Estimation
      - Specifies the measure of risk.
        - Qualitative Estimation
        - Quantitative Estimation

- Risk Evaluation:
    - Compares and prioritizes Risk Level based on Risk Evaluation Criteria and Risk Acceptance Criteria.

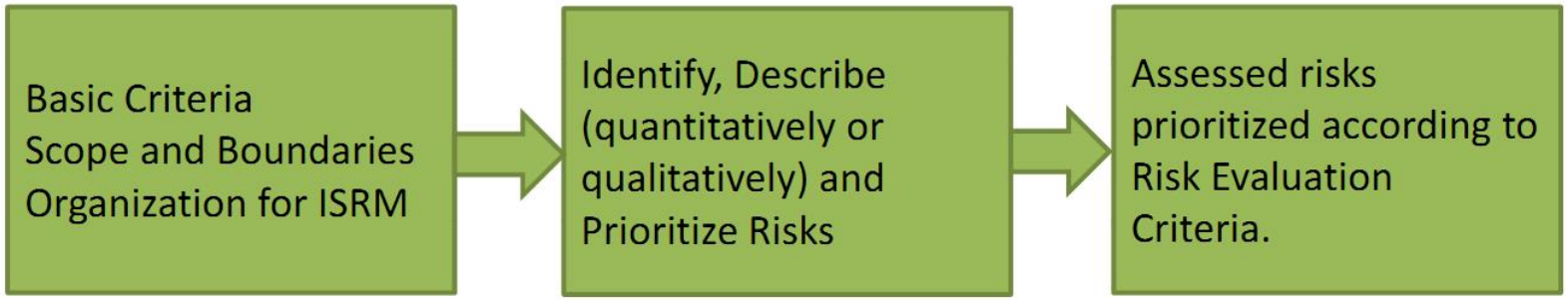
ISO 27005 Workflow



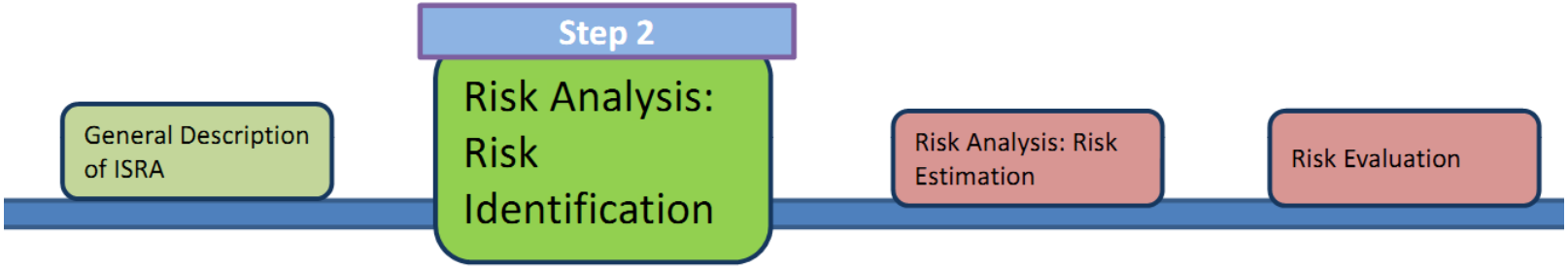
ISO 27005 Workflow



1. General Description of ISRA

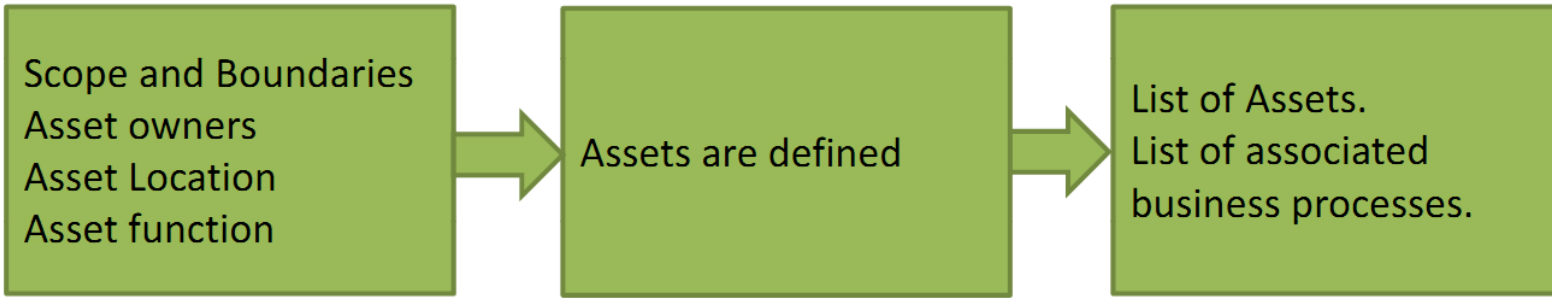


ISO 27005 Workflow

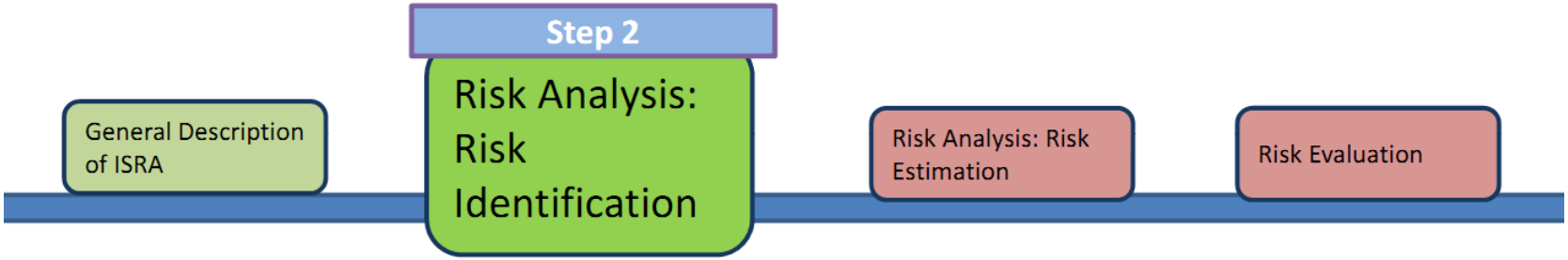


2. Risk Analysis: Risk Identification

Identification of Assets

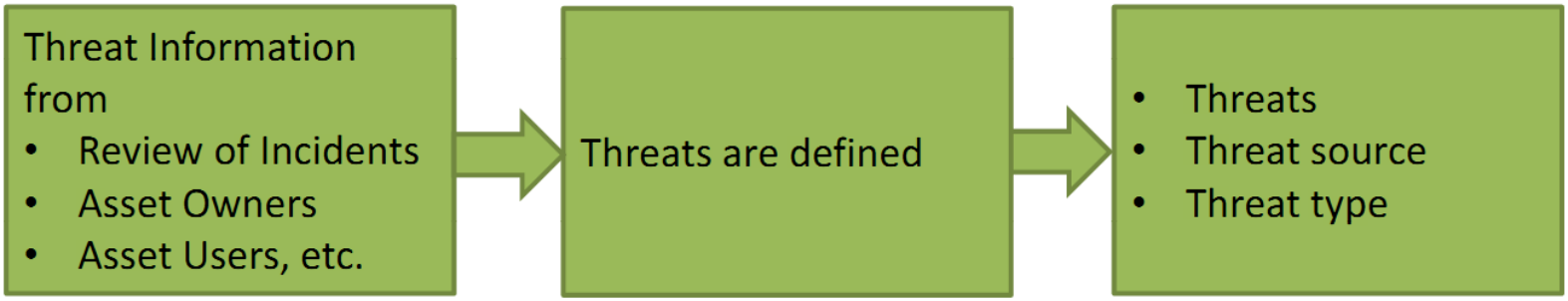


ISO 27005 Workflow

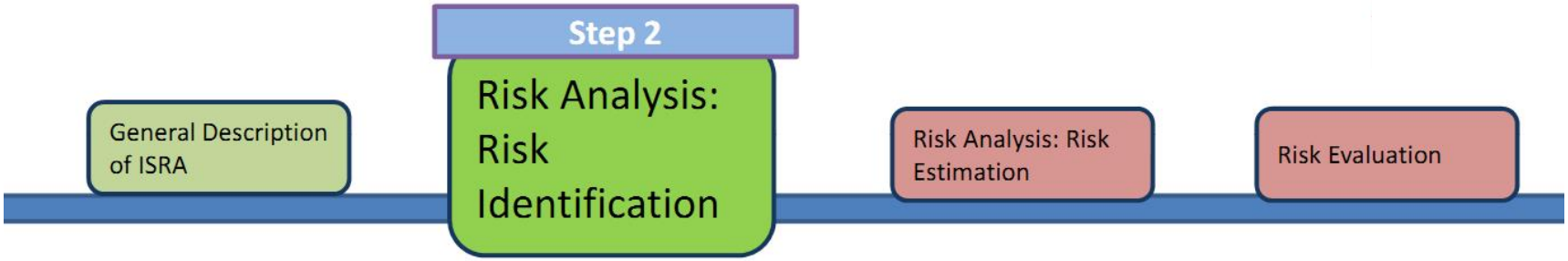


2. Risk Analysis: Risk Identification

Identification of Threats



ISO 27005 Workflow



2. Risk Analysis: Risk Identification

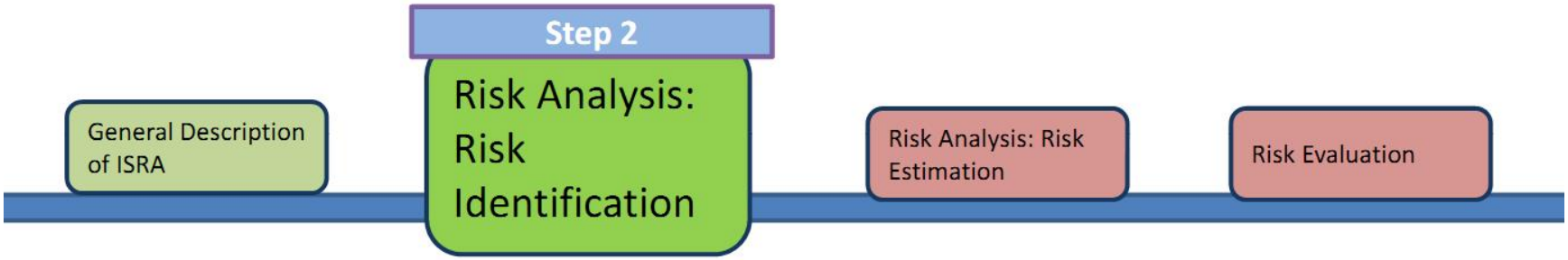
Identification of Existing Controls

- Documentation of controls
- RTP

→ Existing and planned controls are defined →

- Existing and planned controls
- Implementation status
- Usage status

ISO 27005 Workflow



2. Risk Analysis: Risk Identification

Identification of Vulnerabilities

- Identified Assets
- Identified Threats
- Identified Existing Controls

→ Vulnerabilities are identified →

- Vulnerabilities related to assets, threats, controls.
- Vulnerabilities not related to any threat.

ISO 27005 Workflow



2. Risk Analysis: Risk Identification

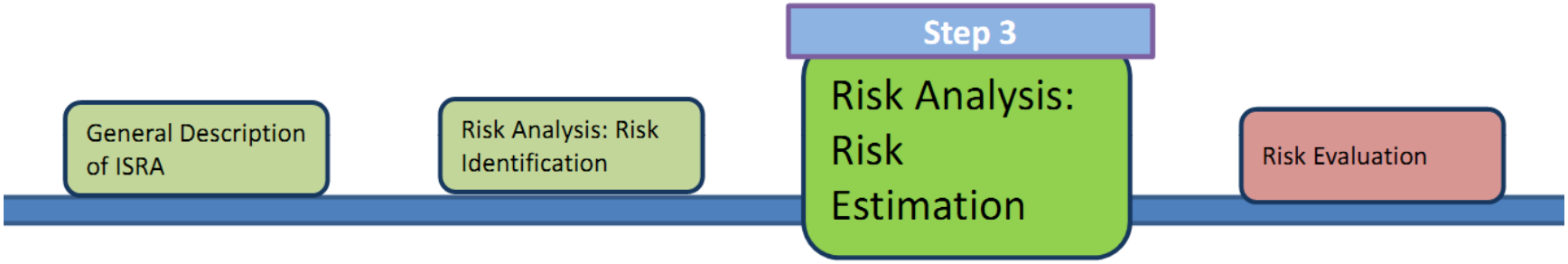
Identification of Consequences

- Assets and business processes
- Threats and vulnerabilities

→ The impact of the loss of CIA is identified →

- Incident scenarios with their consequences related to assets and business processes

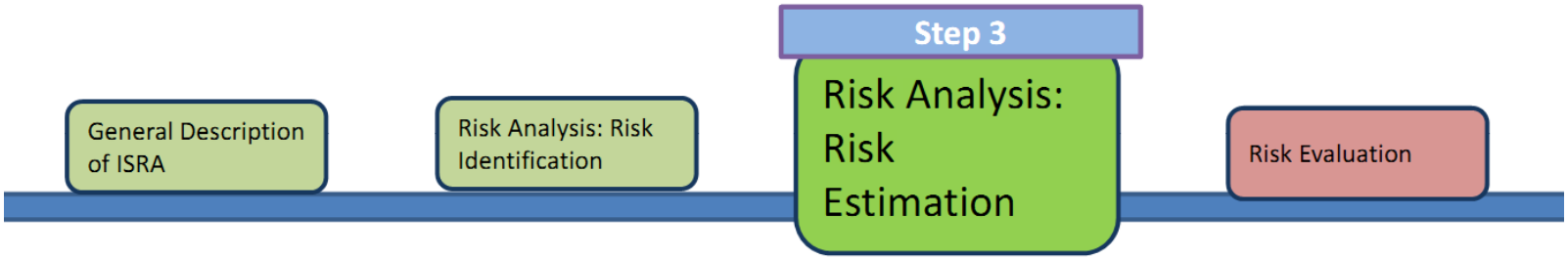
ISO 27005 Workflow



3. Risk Analysis: Risk Estimation

Risk Estimation Methodologies:
(a) Qualitative Estimation: High, Medium, Low
(b) Quantitative Estimation: $, hours, etc.

ISO 27005 Workflow



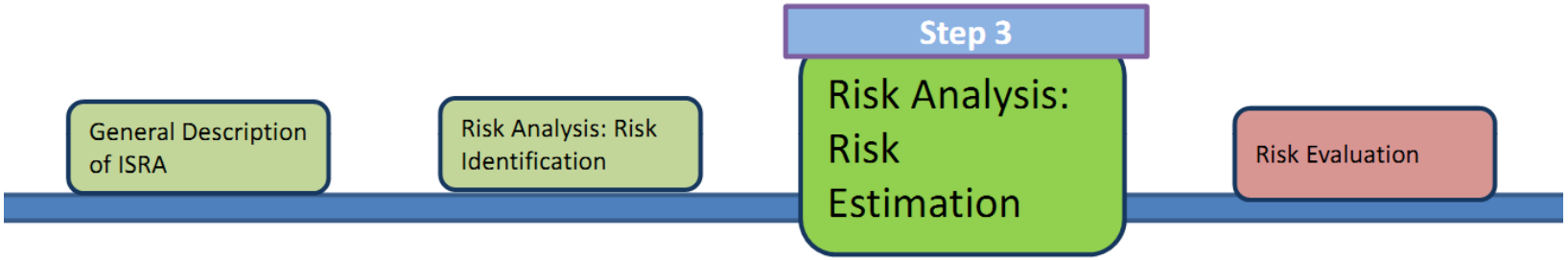
3. Risk Analysis: Risk Estimation

Assessment of consequences

- Assets and business processes
- Threats and vulnerabilities
- Incident scenarios

→ The business impact from information security incidents is assessed. → Assessed consequences of an incident scenario expressed in terms of assets and impact criteria.

ISO 27005 Workflow



3. Risk Analysis: Risk Estimation

Level of Risk Estimation

- Incident scenarios with their consequences
- Their likelihood (quantitative or qualitative).

→ Level of risk is estimated for all relevant incident scenarios

→ List of risks with value levels assigned.

ISO 27005 Workflow



4. Risk Analysis: Risk Evaluation

- Risks with value levels assigned and risk evaluation criteria.

→ Level of risk is compared against risk evaluation criteria and risk acceptance criteria

→ Risks prioritized according to risk evaluation criteria in relation to the incident scenarios.

Risk analysis

Table E.2 Ranking of Threats by measure of risks

Table E.2

	Likelihood of incident scenario	Very Low (Very unlikely)	Low (Unlikely)	Medium (Possible)	High (Likely)	Very High (Frequent)
Business Impact	Very low	0	1	2	3	4
	Low	1	2	3	4	5
	Medium	2	3	4	5	6
	High	3	4	5	6	7
	Very high	4	5	6	7	8

Risk analysis

Table E.3 ranking of threats in order of their associated measure of risks

Table E.3

Threat descriptor (a)	Consequence (asset) value (b)	Likelihood of threat occurrence (c)	Measure of risk (d)	Threat ranking (e)
Threat A	5	2	10	2
Threat B	2	4	8	3
Threat C	3	5	15	1
Threat D	1	3	3	5
Threat E	4	1	4	4
Threat F	2	4	8	3

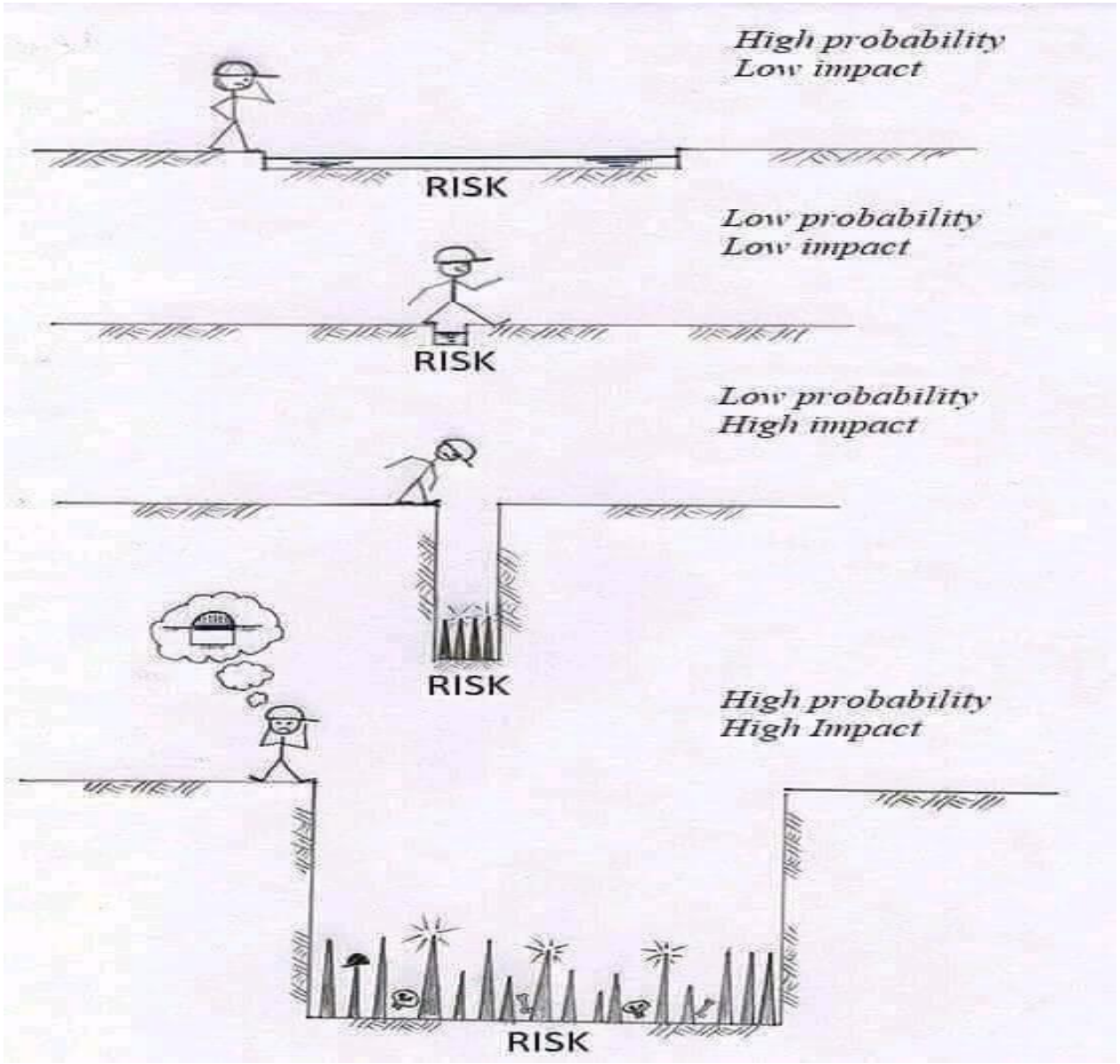
Risk analysis

Table E.4 Likelyhood of an incident scenario

Table E.4

Likelihood of Threat	Low			Medium			High		
Levels of Vulnerability	L	M	H	L	M	H	L	M	H
Likelihood Value of an incident scenario	0	1	2	1	2	3	2	3	4

Assessing risk: probability vs. impact



The decision table

Matrix of acceptance

A: Acceptable – retain, do nothing, prepare recovery

N: NON Acceptable -> countermeasures

Damage value	0	1	2	3	4
Incident frequency value					
0	A	A	A	A	N
1	A	A	A	N	N
2	A	A	N	N	N
3	A	N	N	N	N
4	N	N	N	N	N

Risk evaluation - quantitative

Risk (R) = Threat (T) x Impact (Im) x Annual Rate of Occurrence (ARO) x Asset value (V)

Or

R = T x Im x ARO x V,

where T, Im, ARO, V are the risk factors

Normalised Risk Value (NRV) = R/Rm,

where Rm is the maximum possible value

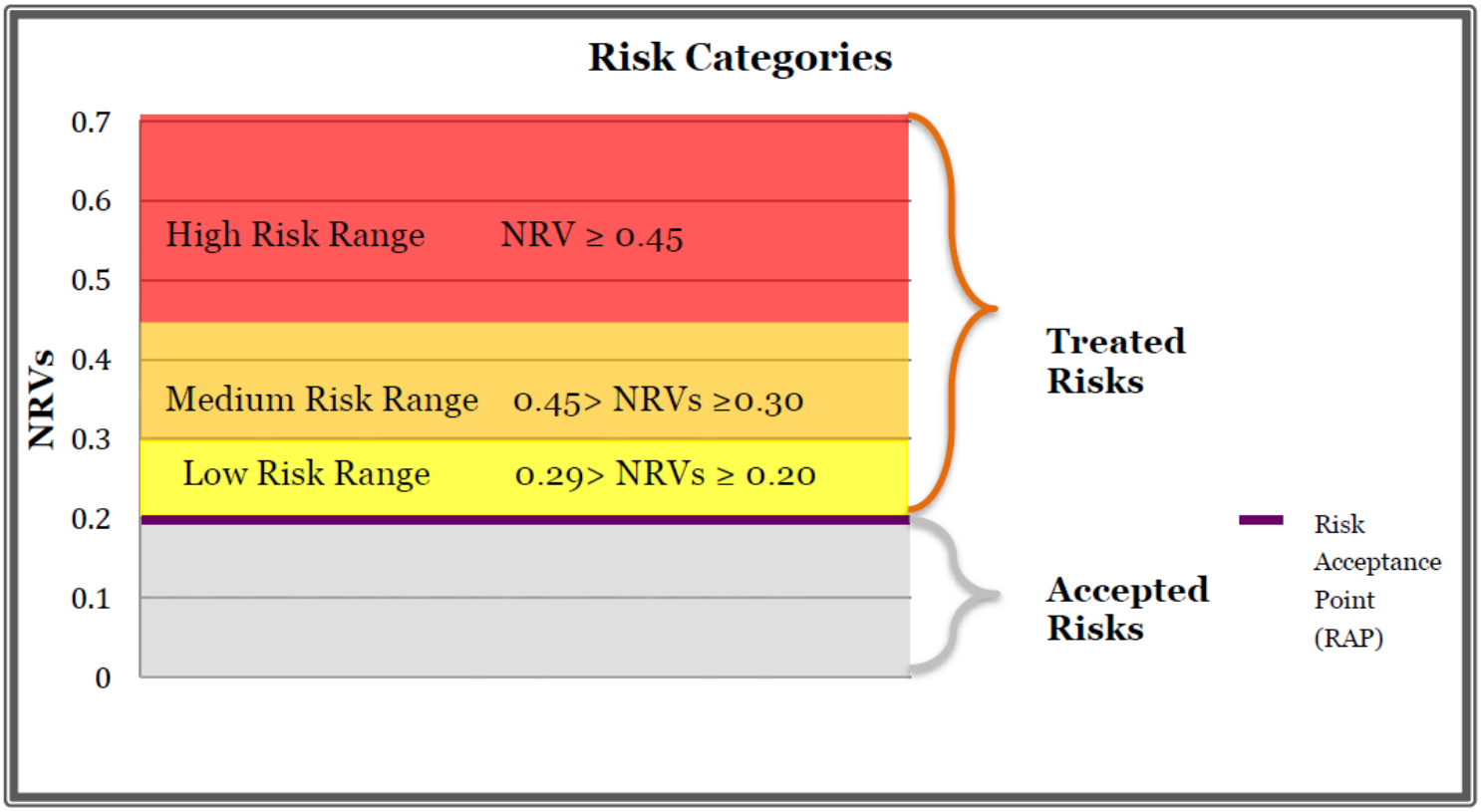
Risk factor definiton

RISK FACTOR DEFINITION	VALUE	RANGE
THREAT (T)	The probability of potential exploitation of an existing weakness or absence of security counter measure; i.e. potential exploitations of an existing vulnerability.	0-1
IMPACT (Im)	The result of an unwanted incident	0-10
ANNUAL RATE OF OCCURENCE (ARO)	Probability of such a risk happening in one year. For instance, if an event definitely happens once in a year, then its value is 1. If an event is probable to happen once in 10 years, then the ARP value is 0.1	0-1
VALUE (V)	Asset Value of the item. It indicates the importance of the asset in terms of Confidentiality, Integrity and Availability on a scale, 1 is least valuable and 3 is most valuable.	1, 2, or 3
RISK (R)	Combination of probability of an event and its consequence	0-30
NORMALISED RISK VALUE (NRV)	NRV Risk on a scale of 0 to 1. Scaling allows consistency in Risk Valuation even if other risk factors and their ranges are changed in future.	0-1

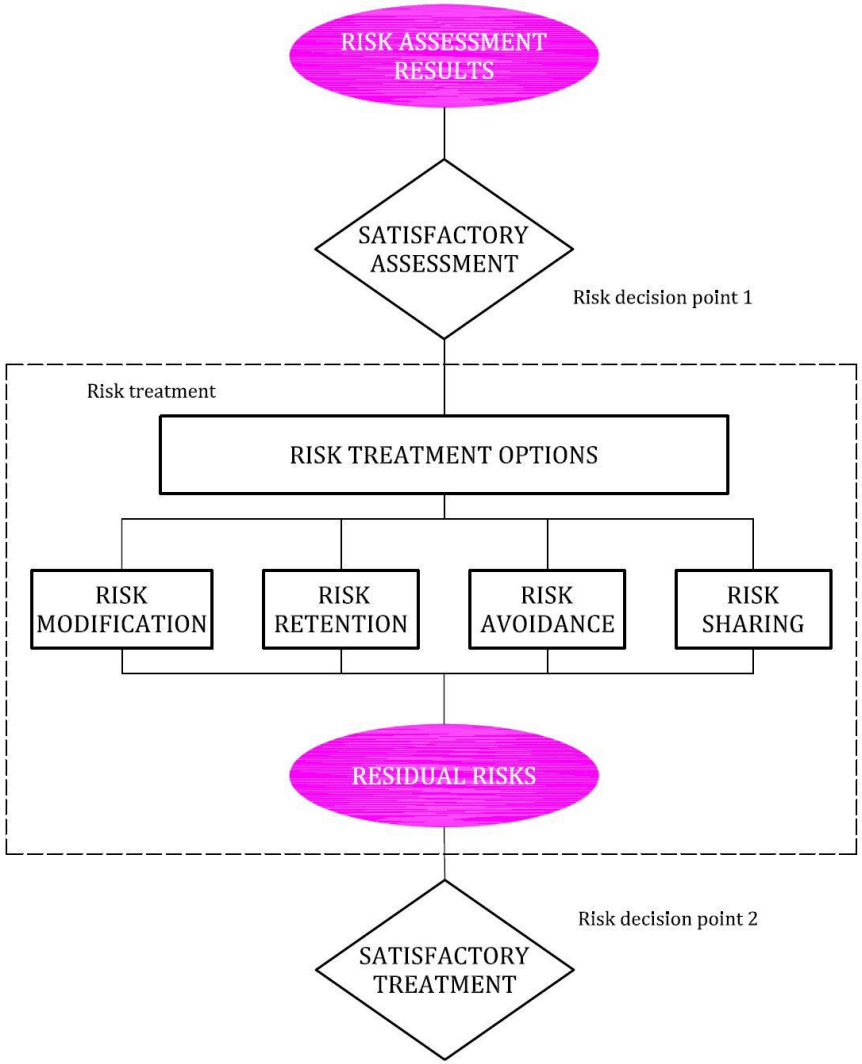
The acceptance threshold (quantitative)

- All risks that fall under a pre-established NRV (threshold) are acceptable and can be retained. No action, only recovery if it happens.
- The risk acceptance criterion for a specific system is (assuming NRV=0.20):
  - ***All risks with NRV < 0.20 are accepted/retained***
  - ***Risks with NRV ≥ 0.20 are acted upon***
- The threshold is modifiable/ied by management during the process of repetition/continuous improvement

mitigate or accept?



Risk Treatment



Information security risk treatment: 4 options

Risk mitigation/reduction

Risk acceptance/retention

Risk avoidance

Risk sharing/transfer

Information security risk acceptance

A management decision:

the executive manager who accepts the risk

the RISK OWNER

is prepared to take care of the consequences

and arrange for recovery in case of disasters

(Business Continuity Framework)

Information security risk communication



Risk Communication

Risk communication should be carried out in order to:

- provide assurance of the outcome of the organization's risk management;
- collect risk information;
- share the results from the risk assessment and present the risk treatment plan;
- avoid or reduce both occurrence and consequence of information security breaches due to the lack of mutual understanding among decision-makers and stakeholders;
- support decision making;
- obtain new information security knowledge;
- coordinate with other parties and plan responses to reduce consequences of any incident;
- give decision-makers and stakeholders a sense of responsibility about risks;
- improve awareness.

The risk communication activity should be performed continually.

Information security risk monitoring and review

The risk assessment exercise must be repeated regularly

Monitoring and review of risk factors

Risk management monitoring, reviewing and improving (continuous improvement, Plan Do Check Act)

Summary

- Keep it Simple and Systematic (KISS)
- Comprehensive across the organization
- Risk sensitive culture in the organization
- Drive security from a risk management perspective, rather than only with a compliance perspective.
- Help Risk Management to help you…

Thank you!

For information:

e-mail
cybersecurity_info@uniroma1.it

Web site
https://cybersecurity.uniroma1.it

Stefano.zatti@gmail.com
Stefano.zatti@uniroma1.it

Google drive for handouts

https://drive.google.com/drive/folders/15-hLIVz4aEroHWc8dkSBqa995iZSJOuT